PROPOSAL

CYBERSECURITY RISK ASSESSMENT AND RANSOMWARE RESILIENCE STRATEGY FOR A MULTI-SITE HEALTHCARE PROVIDER

Institution: International Cybersecurity and Digital Forensics Academy (ICDFA)
Programme: Certified Cybersecurity Consultant
Cohort: Cohort 11
Project Category: Cybersecurity Risk Assessment and Resilience
Case Organisation: Simulated Nigerian Private Healthcare Provider
Proposed Assessment Environment: Isolated Laboratory Using Synthetic Data
Version: 1.0
Submission Date: 27 October 2026
Proposed Final Project Deadline: 22 December 2026

Project Team Members

S/N	Full Name	Registration Number	Assigned Role
1	Alphonsus Stephen Chibuike	C11/26/CSCC/17451	Team Lead and Governance Coordinator
2	Laban Emmanuel Rakum	C11/26/CSCC/17472	Assessment and NIST CSF Lead
3	Nicholas Atacha	C11/26/CSCC/17395	Risk Assessment Lead
4	Oreofe Dada	C11/26/CSCC/17383	Security Architecture Lead
5	Owiliwa Clever Goodluck	C11/26/CSCC/17416	Technical Validation and Backup Recovery Lead
6	Oyewale Akinrinde	C11/26/CSCC/17529	Incident Response, Roadmap and Dashboard Lead

1. INTRODUCTION

Cybersecurity is essential to healthcare organisations that depend on digital systems to manage patient information, appointments, billing, communication, and other critical operations. Ransomware attacks can disrupt these systems, compromise sensitive information, and affect the continuity of healthcare services.

This project, **Cybersecurity Risk Assessment and Ransomware Resilience Strategy for a Multi-Site Healthcare Provider**, will assess a simulated Nigerian healthcare provider operating across two facilities. The project will identify potential cybersecurity risks, evaluate existing and desired security outcomes, and recommend practical measures to strengthen protection, detection, incident response, and recovery.

Using the NIST Cybersecurity Framework (CSF) 2.0 and guidance from NIST SP 800-30 Rev. 1, the team will conduct a structured risk assessment, develop a prioritised risk register, and design security improvements. Selected controls will be demonstrated in an isolated laboratory using synthetic data, subject to supervisor approval.

The project will produce an assessment report, security improvement recommendations, laboratory demonstration results, a ransomware incident response playbook, a tabletop exercise report, a management dashboard, and a costed 90-day improvement roadmap. The work will remain within the approved academic scope and will not involve unauthorised testing of real healthcare systems.

2. BACKGROUND AND PROBLEM STATEMENT

2.1 Background

Healthcare organisations increasingly rely on digital systems to support patient care, appointment management, billing, internal communication, record keeping and coordination between departments. These systems improve efficiency but also introduce cybersecurity risks when access is poorly controlled, software is not maintained, suspicious activities are not detected promptly or recovery procedures are not adequately tested.

Ransomware is a significant concern because it can make business information unavailable, disrupt access to essential systems and potentially expose sensitive information. A successful incident may affect multiple departments or facilities, particularly where systems share network connections, user accounts, administrative privileges or storage resources.

For a healthcare provider, these consequences extend beyond financial loss. Inaccessible patient records may delay administrative and clinical processes. Appointment systems may become unavailable, billing may be interrupted, and staff may need to rely on temporary manual procedures. Recovery may also require technical support, system rebuilding, data validation and communication with affected stakeholders.

A resilience strategy therefore needs to address prevention, detection, response and recovery rather than relying on individual security products alone.

2.2 Description of the Simulated Healthcare Provider

For this project, the case organisation is a simulated Nigerian private healthcare provider with the following assumed characteristics:

- **Facilities:** Two healthcare facilities operating under one organisation.
- **Workforce:** Approximately 80 employees across clinical, administrative, finance, management and IT functions.
- **Critical services:** Patient registration, appointment scheduling, access to patient records, billing, internal communication and administrative reporting.

- **Digital systems:** Electronic patient records, appointment and billing applications, email, shared file storage, user endpoints, network infrastructure and third-party technology services.
- **External dependencies:** Internet connectivity, cloud-based services, software vendors and other approved service providers.
- **Operational priority:** Maintaining access to essential information, protecting sensitive records and restoring critical services following disruption.

The precise technical architecture, software products, number of endpoints, data volumes and existing security controls have not yet been established. These details will be defined in the approved case baseline before the assessment proceeds.

2.3 Scenario Assumptions

The following are **scenario assumptions, not verified findings**:

1. Some users may have privileges beyond those required for their duties.
2. Security updates may not be applied consistently across all supported endpoints and systems.
3. Security monitoring may be limited, fragmented or insufficiently documented.
4. Incident response responsibilities and escalation arrangements may not be clearly defined.
5. The organisation may have backups but insufficient evidence that critical data can be restored successfully within acceptable timeframes.
6. Connections between user devices, servers, shared storage and administrative systems may not provide adequate separation.
7. Some third-party accounts or remote access arrangements may require improved oversight.
8. Staff awareness of ransomware indicators, reporting procedures and safe handling of suspicious messages may vary.

These assumptions will guide the initial risk scenarios and assessment questions. They will not be presented as confirmed weaknesses unless supported by evidence from the approved case study or laboratory.

2.4 Problem Statement

The simulated healthcare provider depends on digital systems to support services across two facilities, yet the assumed weaknesses create uncertainty about its ability to prevent, detect, contain and recover from ransomware.

If excessive privileges, inconsistent patching, inadequate monitoring or insufficiently protected backups exist, an attacker could potentially compromise user accounts or endpoints, disrupt shared systems, affect multiple departments and delay restoration. Weak response arrangements could increase the time required to identify an incident, coordinate decisions and resume essential services.

Potential consequences include service interruption, loss of access to business records, unauthorised disclosure of sensitive information, recovery expenses, reputational damage, contractual difficulties and possible legal or regulatory consequences.

The central problem is therefore the absence of an evidence-based understanding of the organisation's assumed cybersecurity gaps and the controls required to reduce its ransomware risk to a manageable level.

This project will address that problem by assessing the defined case, prioritising risks according to likelihood and impact, designing proportionate improvements and demonstrating selected controls in a safe laboratory.

3. AIM AND OBJECTIVES

3.1 Overall Aim

To assess the cybersecurity risks and ransomware resilience of a simulated multi-site healthcare provider and develop an evidence-based, prioritised and cost-conscious strategy for protecting critical systems, responding to ransomware incidents and restoring essential services.

3.2 Specific Objectives

The project will pursue six measurable objectives:

1. **Asset identification:** Develop a documented inventory of the critical systems, information assets, business processes, user groups and external dependencies represented in the approved case baseline.
2. **Cybersecurity assessment:** Develop a NIST CSF 2.0 Current Profile and Target Profile covering all six CSF functions, identifying documented gaps and their supporting evidence.
3. **Risk prioritisation:** Produce a risk register containing at least 15 distinct ransomware-related or supporting cybersecurity risks, each with a description, likelihood score, impact score, risk rating, proposed owner and recommended treatment.
4. **Security improvement design:** Develop a prioritised security architecture covering identity and access management, endpoint security, network segmentation, monitoring, patch management, third-party access and backup protection.
5. **Control validation and recovery:** Complete three documented control demonstrations in the approved laboratory, including a backup restoration test using synthetic data, and record the test procedure, expected result, actual result and supporting evidence.
6. **Resilience and implementation planning:** Produce a ransomware incident response playbook, conduct one tabletop exercise, develop a management dashboard and prepare a costed 90-day improvement roadmap with priorities, owners, dependencies and measurable indicators.

The objectives will be considered achieved only when the relevant outputs have been completed and reviewed. Where testing cannot be completed, the limitation and reason will be documented rather than reporting an unverified result as successful.

4. SCOPE OF THE ENGAGEMENT

4.1 Systems and Processes Within Scope

The assessment will cover the simulated provider's critical information assets and supporting processes, including:

- Electronic patient record systems and associated data stores.
- Appointment scheduling and patient registration systems.
- Billing and administrative applications.
- Email, collaboration tools and shared file storage.
- User workstations, representative servers and network infrastructure.
- Identity management, authentication and privileged accounts.
- Remote access and third-party access arrangements.
- Endpoint protection, software updates and security configurations.
- Security logging, alert handling and incident escalation.
- Backup arrangements, restoration procedures and recovery priorities.
- Staff responsibilities, security awareness and incident response.
- Business continuity considerations for essential services.

The assessment will consider the two facilities as distinct operational locations connected through the simulated organisation's assumed technology and business arrangements. Where exact network and system relationships are unknown, they will be recorded as design assumptions to be tested or confirmed.

4.2 Security Areas to Be Examined

The assessment will address the six functions of NIST CSF 2.0:

CSF Function	Proposed Assessment Focus
Govern	Cybersecurity responsibilities, policies, risk ownership, third-party oversight and management decisions.
Identify	Asset inventory, critical services, dependencies, sensitive information and risk scenarios.
Protect	Access controls, authentication, endpoint protection, patching, network separation and backups.
Detect	Logging, monitoring, alert identification, review responsibilities and escalation.
Respond	Incident reporting, decision-making, containment, communication and evidence preservation.
Recover	Backup restoration, recovery priorities, data validation, service resumption and lessons learned.

4.3 Exclusions

The following activities are outside the approved proposed scope unless the supervisor formally authorises a change:

- Testing or scanning real healthcare systems.
- Accessing real patient records or personal information.
- Deploying live ransomware or other destructive malware.
- Conducting denial-of-service attacks, phishing campaigns against real users or unauthorised penetration tests.
- Attempting to bypass controls on third-party platforms.
- Making changes to operational systems, production networks or actual backup repositories.
- Certifying legal or regulatory compliance.
- Implementing recommendations in a real organisation as part of the academic assessment.

The project will design and demonstrate selected controls but will not claim that the simulated provider has implemented them in production.

4.4 Constraints and Limitations

The simulated nature of the case means that the initial environment will not provide independently verified evidence of a real provider's security posture. The laboratory will represent only selected systems and behaviours. Tool availability, team experience, time and budget may also limit the depth of technical demonstrations.

Cost estimates will be planning estimates rather than supplier quotations unless verified quotations are obtained. Recommendations that depend on unknown infrastructure or vendor capabilities will be marked for further validation.

4.5 Stakeholder Responsibilities

Stakeholder	Responsibility
Project supervisor	Review the proposed scope and baseline, provide guidance and approve progression to technical testing.

Team lead	Coordinate the engagement, monitor progress and manage scope changes.
Workstream leads	Complete assigned assessment, risk, design, testing and reporting tasks.
Simulated management	Provide the assumed business priorities, approve proposed risk acceptance criteria and review recommendations as part of the case scenario.
Simulated IT and service owners	Supply scenario information and review proposed technical and recovery arrangements.
Real organisation, if later involved	Provide written authorisation, designate contacts and approve the agreed scope before any access or testing.

4.6 Expected Outputs

The engagement is expected to produce an assessment report, asset inventory, Current and Target Profiles, gap analysis, risk register, security improvement design, three control demonstrations, backup restoration evidence, incident response playbook, tabletop exercise report, management dashboard and costed 90-day roadmap.

5. ASSESSMENT METHODOLOGY

5.1 Assessment Approach

The project will use an evidence-based assessment approach informed by the NIST Cybersecurity Framework (CSF) 2.0 and *NIST SP 800-30 Rev. 1, Guide for Conducting Risk Assessments* (NIST, 2012). SP 800-30 Rev. 1 provides guidance for preparing, conducting, and maintaining risk assessments, including the consideration of threats, vulnerabilities, likelihood, impact, and risk responses.

The assessment will proceed through the following stages:

1. Supervisor review and approval of the project scope and case baseline.
2. Identification of critical assets, business processes, and dependencies.
3. Collection and review of available evidence.
4. Development of the NIST CSF 2.0 Current Profile.
5. Identification, analysis, and prioritisation of cybersecurity risks using the project's defined risk-rating criteria.
6. Development of the Target Profile and security improvement design.
7. Controlled laboratory demonstrations and documentation of results.
8. Incident response tabletop exercise.
9. Preparation of the improvement roadmap, dashboard, and final report.

Each stage will produce documented outputs for review before dependent activities proceed. The team will adapt the risk assessment guidance to the simulated healthcare environment and clearly distinguish verified evidence from assumptions and limitations.

5.2 Application of NIST CSF 2.0

The NIST Cybersecurity Framework 2.0 provides six functions—Govern, Identify, Protect, Detect, Respond and Recover—that will be used to organise the assessment and proposed improvements.

Current Profile: The team will document the cybersecurity outcomes supported by the available case information, documents, configuration evidence and laboratory results. Each outcome will be classified as evidenced, partially

evidenced, not evidenced or not applicable. Lack of evidence will not automatically be treated as proof that a control does not exist.

Target Profile: The team will define the desired cybersecurity outcomes based on the criticality of healthcare services, the assessed risks, available resources and the organisation's assumed operational needs.

Gap analysis: The team will compare the Current Profile with the Target Profile. Gaps will be prioritised according to risk, business importance, implementation effort and dependencies.

The CSF will serve as the organising framework; it will not be treated as a certification or as proof of compliance with every applicable legal or regulatory obligation.

5.3 Planned Information-Gathering Activities

A. Interviews and Structured Questions

For the simulated case, the team will use structured interview questions or scenario-based discussions representing the responsibilities of management, IT, clinical services, administration, finance and third-party service owners.

Questions will address critical services, acceptable downtime, sensitive information, user access, security updates, alert handling, incident escalation, backup schedules and recovery expectations.

Where no actual stakeholder is available, responses will be labelled as scenario assumptions rather than interview findings.

B. Document Review

The team will review available or simulated documents, including:

- Asset and software inventories.
- Access control and account management procedures.
- Security policies and patch management records.
- Backup schedules and restoration records.
- Incident response and business continuity procedures.
- Network diagrams and system dependency records.
- Security monitoring and alert-handling procedures.
- Third-party access and service arrangements.

Documents that do not exist within the case will be recorded as unavailable or not provided, rather than assumed to be absent from a real organisation.

C. Asset Identification

The assessment lead will prepare an asset inventory that records each asset's identifier, purpose, location or logical zone, owner, information handled, dependencies, criticality and relevant security controls.

Assets will be prioritised according to their contribution to essential services and the consequences of their loss, compromise or unavailability.

D. Laboratory Evidence

The technical validation lead will record the test objective, authorised test conditions, environment, procedure, expected result, actual result, date, relevant configuration details and evidence reference.

Evidence may include sanitised screenshots, test logs, configuration extracts, restoration verification records and tabletop exercise observations. Evidence will be mapped to the relevant assessment question, risk or proposed control.

5.4 Risk-Rating Method

Each risk will be rated using a five-point likelihood scale and a five-point impact scale.

Risk score = Likelihood × Impact

Score	Likelihood Interpretation	Impact Interpretation
1	Rare	Negligible operational effect
2	Unlikely	Limited disruption
3	Possible	Noticeable disruption requiring management attention
4	Likely	Major disruption to important services or information
5	Almost certain	Severe disruption, widespread impact or critical service interruption

The same 1–5 scale will be applied separately to likelihood and impact.

Risk Score	Rating	Proposed Treatment Priority
1–4	Low	Monitor and manage through routine controls.
5–9	Moderate	Plan treatment and assign an owner.
10–16	High	Prioritise treatment and track progress.
17–25	Critical	Escalate for urgent management review and treatment decisions.

These bands are proposed project criteria, not official NIST risk categories. The team will apply them consistently and explain the basis of each rating. Where evidence is insufficient, the rating will be marked provisional.

Residual risk will be estimated after considering the proposed treatment. It will not be presented as measured improvement unless a subsequent assessment or test supports that conclusion.

5.5 Evidence Quality and Reporting

Findings will be traceable to evidence through unique references. The team will maintain an evidence register with the following fields:

- Evidence ID.
- Related assessment question or risk ID.
- Source and collection method.
- Date collected.
- Description of what the evidence supports.
- Limitations or confidence level.
- Storage location and access classification.

Evidence will be distinguished as **documentary**, **interview/scenario-based**, **laboratory-observed**, **inferred** or **not available**.

The final report will identify which findings are confirmed by laboratory observation, which rely on scenario assumptions and which require further validation. A recommendation will be linked to the risk or gap it addresses, the proposed owner, its priority and the expected evidence of completion.

6. LABORATORY AND ETHICAL ARRANGEMENTS

6.1 Proposed Laboratory Environment

The project will use an isolated laboratory that represents selected parts of the healthcare provider's environment. The proposed setup may include virtual machines or equivalent isolated systems representing user endpoints, a server or shared storage service, a monitoring component and a backup repository.

Potential tools include:

- VirtualBox or another approved virtualisation platform.
- A representative Windows or Linux endpoint.
- Wazuh or an equivalent security monitoring solution.
- A file server or synthetic shared-data environment.
- A backup utility capable of demonstrating backup creation and restoration.
- Spreadsheet or diagramming tools for the risk register, asset inventory and architecture.
- A structured document or dashboard tool for reporting assessment results.

The final tools and configurations will depend on availability, compatibility and supervisor approval. The proposal does not imply that every tool has already been installed or tested for this project.

6.2 Synthetic Data and Test Controls

The laboratory will use fictional patient identifiers, fabricated appointment records, dummy billing data and non-sensitive business files. No real patient information, production credentials or confidential organisational records will be used in the technical demonstrations.

The laboratory will be isolated from production networks and configured to minimise unintended external connectivity. Snapshots or equivalent rollback arrangements will be used where practical. The team will document the laboratory setup before testing and retain a record of material configuration changes.

No live ransomware will be executed. Ransomware-related scenarios will be represented through safe simulations, controlled file operations, benign test events or tabletop exercises.

6.3 Proposed Control Demonstrations

The following three demonstrations are proposed, subject to supervisor approval.

Demonstration 1: Identity and Access Control
The team will demonstrate a least-privilege access arrangement using test accounts and synthetic files. The test will compare authorised and unauthorised access to selected resources and document whether permissions behave as intended.
Expected evidence: Test-account permissions, access-control configuration and records showing the permitted and denied operations.

Demonstration 2: Security Monitoring and Alert Handling
The team will generate benign, controlled test events in the isolated environment and examine whether the selected monitoring tool records relevant events and presents them for review.
Expected evidence: Sanitised event records, alert or detection output where supported, and documentation of the review and escalation procedure.

Demonstration 3: Backup Restoration

The team will create a backup of synthetic business files, select an approved recovery point and restore the data to a designated test location. The restored files will be checked against the original test files for completeness and integrity using suitable methods, such as file counts, checksums or content verification.
Expected evidence: Backup and restoration logs, timestamps, integrity checks, observed restoration duration and any errors or limitations.

The team will report actual results, including failed or incomplete tests. No demonstration will be described as successful until the supporting evidence confirms that the acceptance criteria were met.

6.4 Supervisor Approval and Authorisation

Before technical testing begins, the team will submit the proposed scope and case baseline to the supervisor for review. The submission will define the systems represented, assumptions, test objectives, tools, data types, exclusions, expected evidence and safety measures.

Technical testing must not begin until the supervisor has approved the proposed scope and case baseline.

If a real organisation or system is considered for any part of the work, prior written authorisation from the organisation and any other required approvals must be obtained. The authorisation must define the permitted systems, activities, timing, contacts, information-handling requirements and stop conditions. Supervisor approval alone does not authorise testing of an external organisation.

6.5 Information Handling and Evidence Protection

Project evidence will be stored in an access-controlled location available only to authorised team members and the supervisor where appropriate. Files will use clear identifiers and consistent naming conventions. Sensitive information, if encountered during an authorised activity, will be minimised, protected and handled according to the approved arrangements.

The team will avoid placing credentials, personal information or confidential data in screenshots, presentations or the final report. Evidence copies will be protected against accidental modification where practical. The team lead will coordinate access and retention arrangements, and evidence will be retained or securely deleted in accordance with supervisor instructions and applicable requirements.

6.6 Ethical Considerations

The team will act within the academic scope, follow the principle of least privilege and avoid activities that could disrupt healthcare services or expose sensitive information. The project will not involve unauthorised access, destructive testing or the collection of real patient records.

The final report will disclose methodological limitations and avoid claiming that laboratory results establish the security of an actual healthcare provider. Findings will be presented fairly, and recommendations will reflect both security needs and operational constraints.

7. EXPECTED DELIVERABLES

The project will produce the following outputs.

7.1 Assessment Report: A consolidated report documenting the case baseline, assessment approach, evidence sources, Current Profile, Target Profile, gap analysis, key findings, limitations and recommendations.

7.2 Asset Inventory and NIST CSF Profiles: An inventory of critical assets and dependencies, together with the Current and Target Profiles and a prioritised gap analysis across the six CSF functions.

7.3 Risk Register Containing at Least 15 Risks: The risk register will include, at minimum, the following 15 proposed risk scenarios. They are preliminary risks for assessment, not confirmed findings.

ID	Preliminary Risk Scenario	Potential Impact	Proposed Treatment Direction
R01	Compromise of a user account through phishing or credential theft	Unauthorised access and possible data exposure	MFA, email security and staff awareness
R02	Excessive privileges assigned to user accounts	Unauthorised changes and wider compromise	Least privilege and periodic access reviews
R03	Compromise or misuse of an administrator account	Broad access to systems and data	Separate admin accounts, MFA and privileged access monitoring
R04	Delayed security updates	Exploitation of known vulnerabilities	Risk-based patch management and compliance tracking
R05	Inadequate endpoint protection	Malware execution and endpoint disruption	Managed endpoint protection and alert review
R06	Insufficient network segmentation	Ransomware spreading between systems or facilities	Separate critical services and restrict unnecessary traffic
R07	Inadequate security logging or monitoring	Delayed detection and response	Centralised logging, alert ownership and review procedures
R08	Backups accessible from compromised systems	Backup deletion or corruption	Restricted backup access and protected backup copies
R09	Backup restoration not adequately tested	Prolonged service interruption	Scheduled restoration tests and documented recovery results
R10	Uncontrolled remote access	Unauthorised entry into internal systems	Approved remote access, MFA and session monitoring
R11	Unmanaged third-party accounts	External access persisting beyond business need	Named account owners, time-limited access and periodic reviews
R12	Weak incident escalation arrangements	Delayed containment and unclear decisions	Defined roles, contact lists and escalation thresholds
R13	Inadequate recovery priorities	Critical services restored in the wrong order	Business impact analysis and agreed recovery priorities
R14	Accidental disclosure or loss of sensitive records	Privacy impact, operational disruption and reputational damage	Access restrictions, data handling rules and appropriate protection
R15	Insufficient staff awareness of ransomware indicators	Delayed reporting and increased exposure	Targeted awareness, reporting instructions and exercises

For each risk, the completed register will record the asset or process affected, threat scenario, vulnerability or contributing condition, likelihood, impact, score, rating, evidence reference, existing controls, recommended treatment, risk owner, target date and estimated residual risk.

The final ratings will be assigned after assessment. The table above does not establish that any of these risks has been confirmed in the simulated environment.

7.4 Security Improvement Design: A practical design will recommend appropriate improvements across:

- Identity and access management.
- Multi-factor authentication and privileged account protection.
- Endpoint security and software maintenance.
- Network segmentation and secure remote access.
- Centralised logging and alert review.
- Backup protection and restoration verification.
- Third-party access governance.
- Staff awareness and security responsibilities.

The design will distinguish immediate priorities from improvements requiring additional resources or management decisions.

7.5 Three Control Demonstrations: The team will document three controlled laboratory demonstrations covering access control, security monitoring and backup restoration. Each will include its objective, setup, procedure, expected outcome, actual outcome, evidence and limitations.

7.6 Ransomware Incident Response Playbook: The playbook will describe a practical response sequence covering:

1. Identification and initial reporting.
2. Triage and severity assessment.
3. Escalation to designated decision-makers.
4. Safe containment and protection of unaffected systems.
5. Evidence preservation and investigation.
6. Communication with relevant internal and external stakeholders.
7. Eradication and secure recovery planning.
8. Restoration validation and return to service.
9. Post-incident review and corrective actions.

The playbook will identify proposed roles, decision points, escalation criteria and dependencies. It will not encourage staff to take actions that could endanger patients or disrupt essential services without appropriate authority.

7.7 Tabletop Exercise Report: The team will conduct one discussion-based exercise using a simulated ransomware scenario affecting a business-critical system and potentially both facilities.

The exercise will evaluate whether participants can identify the incident, escalate it, make containment decisions, communicate effectively, protect evidence and agree on recovery priorities. The report will document observations, decisions, gaps and recommended improvements. The exercise will not involve actual malware deployment.

7.8 Management Dashboard: The dashboard will provide a concise view of cybersecurity and recovery readiness. Proposed indicators include:

- Percentage of critical assets recorded in the inventory.
- Percentage of privileged accounts reviewed.
- Percentage of priority accounts protected by MFA.
- Percentage of supported endpoints meeting the agreed update status.
- Percentage of scheduled backups completed successfully.
- Percentage of planned restoration tests completed.

- Time taken to restore synthetic data in the laboratory.
- Percentage of priority alerts assigned an owner and reviewed within the agreed timeframe.
- Number of unresolved high and critical risks.
- Percentage of implementation actions completed on schedule.
- Percentage of relevant staff completing the planned awareness activity.
- Percentage of third-party accounts with a documented owner and approved access scope.

Baseline values and targets will be proposed where evidence permits. Targets will not be reported as achieved unless actual results support them.

7.9 Costed 90-Day Improvement Roadmap: The roadmap will group recommendations into three phases.

Phase	Period	Main Priorities	Expected Outputs
Phase 1	Days 1–30	Confirm asset ownership, review privileged access, enable or strengthen MFA where feasible, address urgent supported-system updates, verify backup arrangements and assign incident response roles	Prioritised action register, access review, initial remediation plan and recovery responsibilities
Phase 2	Days 31–60	Improve endpoint visibility, strengthen logging, refine network separation, review third-party access and conduct an initial restoration test	Updated control records, monitoring improvements, access decisions and restoration evidence
Phase 3	Days 61–90	Conduct a follow-up recovery test, run the tabletop exercise, review remaining high risks, update procedures and establish management reporting	Exercise report, updated risk register, dashboard and next-cycle improvement plan

The costed roadmap will estimate implementation effort and potential costs for staffing, training, tools, licensing, infrastructure and external support where relevant. Estimates will be presented in Nigerian naira where suitable, with assumptions and pricing dates documented. The team will distinguish planning estimates from verified supplier quotations.

The roadmap is a proposed implementation plan; the project team will not claim that the simulated provider has completed these actions.

8. WORK PLAN AND REFERENCES

8.1 Weekly Schedule

The proposed schedule covers eight weeks, beginning on 27 October 2026 and ending on 22 December 2026. It is a planning baseline and must be adjusted to the supervisor's confirmed deadline.

Week / Proposed Dates	Activities	Lead Owner(s)	Dependencies and Review Points
Week 1: 27 Oct–2 Nov	Confirm project charter, team roles, scope, assumptions and initial case baseline. Prepare submission for supervisor review.	Alphonsus; all members	Supervisor must review the proposed scope and baseline before technical testing.
Week 2: 3–9 Nov	Refine asset inventory, stakeholder questions, evidence register and NIST CSF assessment questions.	Laban; Alphonsus	Requires an agreed case baseline and review of available scenario documents.

Week 3: 10–16 Nov	Develop Current Profile, identify gaps, define risk-rating criteria and prepare preliminary risk register.	Laban; Nicholas	Review evidence quality, assumptions and consistency of scoring.
Week 4: 17–23 Nov	Complete risk prioritisation and develop the Target Profile and security improvement architecture.	Nicholas; Oreofe	Depends on asset inventory and initial gap analysis.
Week 5: 24–30 Nov	Finalise the laboratory plan and conduct approved access-control and monitoring demonstrations.	Owiliwa; Oreofe	Technical testing requires supervisor approval of the scope and case baseline.
Week 6: 1–7 Dec	Conduct backup restoration demonstration; develop the incident response playbook and tabletop scenario.	Owiliwa; Oyewale	Requires an approved laboratory, synthetic data and documented test procedures.
Week 7: 8–14 Dec	Conduct tabletop exercise, prepare dashboard, costed roadmap and draft report.	Oyewale; Alphonsus; all members	Depends on assessment outputs, risk register and available cost assumptions.
Week 8: 15–22 Dec	Validate evidence references, review risks and recommendations, consolidate the report, quality-check references and prepare final presentation and submission.	Alphonsus; all members	Final team review and supervisor feedback must be addressed before submission.

Review and Change Control

The team will conduct at least one progress review each week. Each workstream lead will report completed activities, evidence collected, outstanding tasks, risks to delivery and support required.

The team lead will maintain an action log and record significant decisions. If a task is delayed or a material scope change becomes necessary, the team will document its effect on dependencies and the final deadline and seek supervisor guidance where required.

8.2 Project Management and Quality Assurance

Quality assurance will focus on the following:

- Every assessment conclusion will have a source or be labelled as an assumption.
- Each risk will have a unique identifier and a documented treatment direction.
- The risk register, CSF gap analysis and recommendations will use consistent terminology.
- Technical tests will have predefined expected results and documented actual results.
- Failed or incomplete tests will be reported transparently.
- Cost estimates will identify assumptions and will not be represented as confirmed quotations.
- The final report will be reviewed for completeness, clarity, consistent references and alignment with the approved scope.

8.3 Expected Project Outcomes

The project is expected to provide a structured understanding of the simulated provider's principal cybersecurity risks and the controls most likely to reduce its exposure to ransomware.

The resulting assessment will connect critical assets and business services to documented risks, desired cybersecurity outcomes and recommended improvements. The laboratory demonstrations will provide limited but traceable evidence of selected control behaviours, including the ability to restore synthetic business data under the tested conditions.

The incident response playbook and tabletop exercise will help identify weaknesses in decision-making, escalation and recovery planning. The dashboard and 90-day roadmap will translate the findings into practical priorities that management can review and track.

The quality of the conclusions will depend on the completeness of the case baseline, available evidence and the scope of laboratory testing. The project will not claim to prove the security of an actual healthcare provider.

8.4 Conclusion

Ransomware resilience requires a coordinated approach to cybersecurity governance, asset identification, access control, threat detection, incident response and recovery. For a healthcare provider operating across two facilities, these measures must be considered alongside the need to maintain essential services and protect sensitive information.

This proposal establishes a structured plan for assessing a simulated healthcare provider using NIST CSF 2.0, documenting and prioritising at least 15 risks, designing security improvements, validating selected controls in an isolated laboratory and preparing practical response and recovery arrangements.

The project will use synthetic data, evidence-based reporting and supervisor-approved testing boundaries. By linking each recommendation to a risk, evidence source, responsible owner and implementation priority, the team aims to produce a practical ransomware resilience strategy that supports informed management decisions.

The project will proceed to technical assessment only after the supervisor has reviewed and approved the proposed scope and case baseline.

REFERENCES

Bartock, M., Cichonski, J., Souppaya, M., Smith, M., Witte, G., & Scarfone, K. (2016). Guide for cybersecurity event recovery (NIST Special Publication 800-184). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-184

Cybersecurity and Infrastructure Security Agency. (2023). #StopRansomware guide. https://www.cisa.gov/resources-tools/resources/stopransomware-guide

National Institute of Standards and Technology. (2020a). Data integrity: Detecting and responding to ransomware and other destructive events (NIST Special Publication 1800-26). https://www.nccoe.nist.gov/publication/1800-26/

National Institute of Standards and Technology. (2020b). Data integrity: Identifying and protecting assets against ransomware and other destructive events (NIST Special Publication 1800-25). https://www.nccoe.nist.gov/publication/1800-25/

National Institute of Standards and Technology. (2020c). Data integrity: Recovering from ransomware and other destructive events (NIST Special Publication 1800-11). https://www.nccoe.nist.gov/publication/1800-11/

National Institute of Standards and Technology. (2020d). Security and privacy controls for information systems and organizations (NIST Special Publication 800-53, Rev. 5). https://doi.org/10.6028/NIST.SP.800-53r5

National Institute of Standards and Technology. (2020e). Zero trust architecture (NIST Special Publication 800-207). https://doi.org/10.6028/NIST.SP.800-207

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST Cybersecurity White Paper 29). https://doi.org/10.6028/NIST.CSWP.29

National Institute of Standards and Technology. (2025). Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile (NIST Special Publication 800-61, Rev. 3). https://doi.org/10.6028/NIST.SP.800-61r3

National Institute of Standards and Technology. (2026). Ransomware risk management: A Cybersecurity Framework 2.0 community profile (NIST Interagency Report 8374, Rev. 1). https://doi.org/10.6028/NIST.IR.8374r1

Neprash, H. T., McGlave, C. C., Cross, D. A., Virnig, B. A., Puskarich, M. A., Huling, J. D., Rozenshtein, A. Z., & Nikpay, S. S. (2022). Trends in ransomware attacks on US hospitals, clinics, and other health care delivery organizations, 2016–2021. JAMA Health Forum, 3(12), Article e224873. https://doi.org/10.1001/jamahealthforum.2022.4873

Nigeria Data Protection Act, 2023, Act No. 37 of 2023 (Nigeria). https://ndpc.gov.ng/

APPENDIX A: INDIVIDUAL CONTRIBUTION LOG TEMPLATE

Each member should complete a separate contribution log throughout the project. Entries should describe work actually performed and identify supporting outputs where possible.

Date	Member's Full Name	Assigned Workstream	Task Completed	Evidence / Output Reference	Challenges or Dependencies	Next Action	Member Confirmation

Instructions: Record contributions as they occur. Do not claim tasks that have not been completed. Evidence or output references may include document names, risk IDs, assessment records, laboratory test IDs or meeting decisions.

APPENDIX B: PROPOSED EVIDENCE REGISTER TEMPLATE

Evidence ID	Related Risk / CSF Outcome	Evidence Type	Source or Test	Date	What It Supports	Limitations / Confidence	Storage Reference
E-001							
E-002							
E-003							

APPENDIX C: PROPOSED RISK REGISTER FIELDS

The completed risk register should include the following fields:

1. Risk ID and risk title.
2. Asset or business process affected.
3. Threat scenario and contributing weakness.
4. Potential business impact.
5. Evidence reference and evidence status.
6. Likelihood score, from 1 to 5.
7. Impact score, from 1 to 5.
8. Calculated risk score and rating.
9. Existing controls, where evidenced.
10. Recommended treatment.
11. Assigned risk owner.
12. Target completion date.
13. Estimated residual risk.
14. Treatment status and review date.